TP — Analyse de risques SSI avec MEHARI

Guide étudiant, déroulé de séance et modalités de restitution

Cadre	Indication
Public visé	Étudiants en administration cloud, cybersécurité, systèmes et réseaux
Outil principal	Template MEHARI au format Excel macro-activé
Travail	Binôme ou groupe de 3 étudiants maximum
Livrables	Classeur MEHARI complété + dossier de synthèse

1. Finalité du TP

Ce TP vous place dans la situation d'une équipe chargée d'évaluer les risques du système d'information d'une organisation. Vous appliquerez une démarche structurée inspirée de MEHARI afin d'identifier les actifs critiques, évaluer les mesures de sécurité existantes, analyser les scénarios de risque prioritaires et proposer un plan d'action réaliste.

L'objectif n'est pas de renseigner mécaniquement un tableur : chaque choix doit être relié à une conséquence métier, à une hypothèse explicitée ou à une observation issue du cas étudié. Le résultat attendu est un document d'aide à la décision pour une direction ou un comité de pilotage SSI.

2. Compétences visées

- Délimiter un périmètre d'analyse des risques et formuler des hypothèses de travail.
- Identifier les activités métier, données, services, processus et actifs supports importants.
- Évaluer les enjeux selon la disponibilité, l'intégrité, la confidentialité et, si pertinent, l'efficience.
- Mesurer le niveau de maturité de services de sécurité au moyen d'un questionnaire structuré.
- Sélectionner et justifier des scénarios de risque significatifs.
- Interpréter un niveau de risque résiduel et prioriser les risques à traiter.
- Construire un plan de traitement assorti de responsables, d'échéances, de coûts indicatifs et d'indicateurs de suivi.
- Présenter une synthèse claire et argumentée à un public non technique.

3. Étude de cas proposée

Vous êtes missionnés par une PME fictive, « Alsace Formation Numérique » (AFN), qui conçoit et dispense des formations professionnelles hybrides. L'organisation emploie 45 personnes, accueille environ 1 200 apprenants par an et exploite plusieurs services numériques : site vitrine, plateforme LMS, messagerie collaborative, CRM, stockage cloud, solution de facturation et postes de travail administratifs.

Contexte et contraintes

- Les données traitées comprennent les identités et coordonnées des apprenants, dossiers de financement, feuilles d'émargement, résultats d'évaluation, contrats, factures et données de ressources humaines.
- La plateforme LMS, les visioconférences et la messagerie sont indispensables pendant les périodes de formation.
- Une partie des services est hébergée chez des prestataires cloud ; l'entreprise dispose aussi d'un NAS local et de quelques serveurs virtuels.
- Le télétravail est autorisé. Les comptes administrateurs et les comptes de formateurs disposent de droits variables selon les applications.
- La direction souhaite renforcer la résilience après plusieurs incidents mineurs : hameçonnage, indisponibilité d'un outil SaaS, erreurs de partage de fichiers et absence ponctuelle de sauvegardes vérifiées.
- Les moyens financiers sont limités : les recommandations devront donc être priorisées et proportionnées.

Périmètre minimal obligatoire

- Le processus d'inscription et de gestion administrative des apprenants.
- Le processus de délivrance des formations à distance ou hybrides.
- La gestion des données personnelles, contractuelles et financières.
- Les services de messagerie, stockage collaboratif, LMS et accès distant.
- Les postes de travail, comptes à privilèges, sauvegardes et équipements réseau essentiels.

4. Avant de commencer

Avant toute saisie dans le classeur MEHARI, réalisez les actions suivantes :

1. Créer un dossier de travail partagé et conserver une version datée du fichier MEHARI utilisé.
2. Désigner les rôles au sein du groupe : pilote de l'analyse, responsable actifs et enjeux, responsable diagnostic et risques, responsable restitution.
3. Lire les feuilles Intro, Présentation et Param du classeur.
4. Activer uniquement les modules nécessaires : classification, services, analyse et traitement.
5. Créer un journal d'hypothèses : toute information absente du cas doit être formulée explicitement comme hypothèse.
6. Définir les conventions de nommage des actifs, applications, processus et scénarios afin de garantir la cohérence du travail.

5. Déroulé recommandé

Séance 1 — Enjeux et actifs

Objectif : comprendre l'activité d'AFN et déterminer ce qui doit être protégé en priorité.

7. Identifier au moins cinq activités majeures et préciser pour chacune sa finalité, ses acteurs, ses entrées, ses résultats et ses dépendances numériques.
8. Identifier les dysfonctionnements redoutés : retard, indisponibilité, erreur, divulgation, perte, non-conformité ou absence de contrôle.

9. Établir une échelle de gravité adaptée au contexte. Décrire avec des exemples ce qui correspond à un impact faible, modéré, important et critique.
10. Dans la feuille Classif, sélectionner les types d'actifs réellement pertinents pour le cas.
11. Compléter T1 pour les données et T2 pour les services et processus.
12. Justifier chaque niveau élevé de disponibilité, intégrité ou confidentialité dans le journal d'hypothèses.

Résultat attendu : un inventaire ciblé et qualifié ; évitez de recenser tous les actifs possibles sans hiérarchisation.

Exemple d'actif	D	I	C	Justification attendue
Dossiers de financement des apprenants	Élevée	Élevée	Élevée	Retard de prise en charge, erreurs administratives, exposition de données personnelles et financières.
Plateforme LMS	Élevée	Moyenne à élevée	Moyenne	Interruption des formations, altération de contenus ou de résultats, accès d'apprenants non autorisés.
Site vitrine public	Moyenne	Moyenne	Faible	Atteinte à l'image et perte d'opportunités commerciales, mais confidentialité limitée.

Séance 2 — Services de sécurité et scénarios

Objectif : évaluer les protections actuelles et en déduire les scénarios de risque prioritaires.

13. Choisir une seule variante de notation des questionnaires, V1, V2, V3 ou V4, et l'utiliser de façon uniforme.
14. Renseigner prioritairement les questionnaires liés à l'organisation, aux systèmes, à l'exploitation, aux applications, aux postes de travail et à l'environnement externe.
15. Attribuer une note de 0 à 4 : 0 = inexistant, 1 = partiel, 2 = en place mais incomplet, 3 = correctement mis en œuvre, 4 = mature et documenté.
16. Documenter une preuve, une observation ou une hypothèse pour toute note de 0, 1 ou 2 sur un contrôle important.
17. Analyser l'onglet Services et identifier les sous-services dont la note est inférieure à l'objectif.
18. Dans Expo, vérifier les expositions naturelles : ne les modifiez que si le contexte de l'organisation le justifie.
19. Dans Scénarios, filtrer la base et retenir entre 10 et 20 scénarios pertinents. Exclure explicitement les scénarios hors périmètre.
20. Calculer puis examiner les risques résiduels dans les vues liées aux actifs et aux événements.

Règle de sélection des scénarios

Chaque scénario conservé doit répondre à trois questions : quel actif est touché ? quel événement ou acteur est en cause ? quelle conséquence métier redoute-t-on ? Une sélection courte, justifiée et reliée au périmètre vaut mieux qu'une analyse exhaustive non maîtrisée.

Séance 3 — Traitement, pilotage et restitution

Objectif : transformer les constats en décisions de sécurité proportionnées.

21. Retenir les cinq à huit risques les plus significatifs ou les plus urgents.
22. Choisir pour chacun une stratégie : accepter, réduire, transférer ou éviter.
23. Renseigner Plans_action avec une mesure précise, le risque ciblé, le responsable, l'échéance, les prérequis et un indicateur de réalisation.
24. Regrouper les actions cohérentes dans Projets : par exemple gestion des identités, sauvegarde et reprise, sécurisation des postes, gouvernance SSI.
25. Estimer un coût ou une charge de mise en œuvre avec une granularité simple : faible, moyen ou élevé.
26. Consulter Delta et Tbord pour visualiser les écarts de maturité et préparer votre synthèse de direction.
27. Vérifier que chaque action est reliée à un ou plusieurs scénarios et à un service de sécurité à améliorer.

6. Livrables attendus

Livrable	Contenu minimal	Format
1. Classeur MEHARI	Feuilles T1, T2, Expo, questionnaires sélectionnés, Services, Scénarios et Plans_action complétés.	Fichier Excel macro-activé, conservant les formules et macros.
2. Dossier d'analyse	Contexte, périmètre, hypothèses, actifs critiques, justification DIC, risques prioritaires et plan de traitement.	Document de 8 à 12 pages hors annexes.
3. Registre des risques	Entre 10 et 20 scénarios analysés ; présentation détaillée des 5 à 8 risques prioritaires.	Tableau intégré au dossier ou exporté.
4. Feuille de route	Actions, responsable, priorité, charge/coût, échéance, dépendances et indicateur.	Tableau de pilotage.
5. Restitution orale	Présentation destinée à la direction : risques majeurs, décisions demandées, feuille de route.	10 minutes + 5 minutes de questions.

Structure imposée du dossier

28. Résumé exécutif : une page maximum, rédigée pour la direction.
29. Présentation du contexte, du périmètre et des hypothèses.
30. Méthode suivie et limites de l'analyse.
31. Actifs, activités et enjeux de sécurité.
32. Évaluation des services de sécurité et principaux écarts.
33. Registre des risques et analyse des risques prioritaires.
34. Plan de traitement et feuille de route de mise en œuvre.
35. Conclusion : décisions attendues, risques acceptés et étapes de suivi.
36. Annexes : journal d'hypothèses, extraits pertinents du classeur, éléments de preuve ou tableaux détaillés.

7. Modèles de tableaux

Journal des hypothèses

Réf.	Hypothèse / observation	Impact sur l'analyse	Validation requise
H-01	Le MFA n'est pas systématiquement activé pour les comptes administrateurs.	Augmente le risque de compromission de compte.	À confirmer par le responsable IT.
H-02	Les sauvegardes cloud ne font pas l'objet de tests de restauration trimestriels.	Risque de reprise incertaine après incident.	À confirmer par l'équipe exploitation.
H-03	Les données de formation sont hébergées chez un prestataire situé dans l'UE.	Influence les risques de conformité et de disponibilité fournisseur.	À vérifier dans le contrat.

Registre des risques prioritaires

Risque	Actif / processus	Scénario	Niveau résiduel	Décision	Justification
R-01	LMS et comptes formateurs	Compromission d'un compte via hameçonnage.	À reporter depuis MEHARI	Réduire	MFA, sensibilisation ciblée, revue des privilèges et supervision.
R-02	Dossiers apprenants	Divulgation par partage cloud mal configuré.	À reporter depuis MEHARI	Réduire	Classification, restrictions de partage, revue des droits et journalisation.
R-03	Continuité des formations	Indisponibilité d'un service SaaS critique.	À reporter depuis MEHARI	Réduire / transférer	PCA, procédure de contournement, engagements contractuels et tests.

Plan de traitement

Action	Risques concernés	Responsable	Priorité	Échéance	Indicateur
Déployer le MFA pour tous les comptes à privilèges et accès distants.	R-01 et scénarios connexes	Responsable IT	P1	Mois 1	100 % des comptes concernés enrôlés.
Formaliser et tester une restauration de sauvegarde.	R-03 et perte de données	Exploitation	P1	Mois 2	Test documenté et objectif de reprise atteint.
Revoir les règles de partage des espaces	R-02	Référent données / IT	P2	Mois 2	Aucun lien public non justifié ; revue trimestrielle.

collaboratifs.					
Adopter une politique de gestion des accès et des départs.	Accès non autorisé	Direction / RH / IT	P2	Mois 3	Processus validé et contrôles d'échantillon conformes.

8. Grille d'évaluation

Critère	Attendus	Pondération
Cadrage et périmètre	Périmètre clair, hypothèses explicites, articulation avec le contexte métier.	15 %
Analyse des actifs et enjeux	Inventaire ciblé, niveaux DIC cohérents, justifications concrètes.	20 %
Diagnostic des services	Notation homogène, preuves ou hypothèses, interprétation des écarts.	15 %
Analyse des risques	Scénarios pertinents, sélection maîtrisée, lecture correcte du risque résiduel.	20 %
Plan de traitement	Actions réalistes, priorisées, reliées aux risques et pilotables.	20 %
Qualité de la restitution	Clarté, précision, capacité à défendre les choix et qualité de la synthèse exécutive.	10 %

9. Points de vigilance

- Ne confondez pas une vulnérabilité, une menace, un scénario de risque et une mesure de sécurité.
- Ne mettez pas systématiquement le niveau maximal à tous les actifs : une cotation élevée doit être justifiée par une conséquence métier identifiable.
- Ne modifiez pas les paramètres ou l'exposition naturelle sans conserver une trace du motif.
- Ne sélectionnez pas plusieurs centaines de scénarios : concentrez-vous sur les situations plausibles et significatives pour le périmètre.
- Ne déduisez pas qu'un risque est nul parce qu'un contrôle existe ; évaluez le niveau réel de mise en œuvre et son efficacité.
- N'annoncez pas une action sans responsable, date, ressources et indicateur : ce ne serait pas un plan de traitement pilotable.
- Ne laissez pas les macros ou les formules du classeur être écrasées lors de l'édition ou de l'export.

10. Questions de restitution orale

- Quels sont les trois risques qui nécessitent une décision de direction immédiate, et pourquoi ?
- Quels actifs ou processus ont obtenu les niveaux d'enjeux les plus élevés ?
- Quels écarts de sécurité expliquent le plus fortement les risques résiduels ?
- Quelles actions apportent le meilleur gain de sécurité à court terme ?

- Quels risques l'organisation pourrait accepter temporairement, sous quelles conditions et avec quelle surveillance ?
- Comment mesurerez-vous dans six mois que le plan de traitement a amélioré la situation ?

Annexe — Rappel du cycle MEHARI

Le cycle de travail à retenir est le suivant :

37. Comprendre les activités et les conséquences redoutées.
38. Classer les données, services et processus selon les enjeux.
39. Évaluer l'exposition naturelle aux événements redoutés.
40. Diagnostiquer les services de sécurité existants.
41. Sélectionner et évaluer les scénarios de risque.
42. Déterminer le risque résiduel et décider du traitement.
43. Mettre en œuvre, suivre et réévaluer les actions.

Consigne finale : privilégiez la cohérence, la justification et la capacité à décider plutôt que la quantité de cellules renseignées.